MDR · CONSOLA DE TRIAJE

Manual de usuario

MDR de triaje asistido: detección refinada, respuesta con control humano

Versión	**9 de noviembre de 2026**
Para	**Analistas del SOC y administración del MDR**
Cubre	**Puesta en marcha, consola web, configuración y referencia**

Para quién es y cómo leerlo

Este manual es para las dos personas que usan el sistema:

- **El analista del SOC.** Trabaja con la consola web cada día: revisa lo que el MDR decide, aprueba o corrige las respuestas, sigue los incidentes y saca informes. Su parte es la **II**.
- **El administrador del MDR.** Lo pone en marcha, da de alta los equipos del cliente, ajusta las políticas y mantiene el perfil de la red. Sus partes son la **I** y la **III**.

La **parte IV** es de consulta para los dos: familias de ataque, causas de fallo, variables y problemas comunes.

Los textos entre «comillas» son literales de la pantalla. Los comandos se ejecutan desde la raíz del repositorio.

Otros documentos. `RUNBOOK.md` tiene el detalle técnico del laboratorio y de los flags. `guia-de-operacion.md` cubre la operación en producción (servicio systemd, anclaje de la traza, verificación periódica). `referencia-api.md` describe la API.

Índice

- Qué hace el sistema
- **Parte I · Puesta en marcha**
  - 1. Requisitos
  - 2. Arrancar el laboratorio y el MDR
  - 3. Entrar en la consola
  - 4. Detener el sistema
- **Parte II · Uso diario (analista)**
  - 5. La pantalla
  - 6. Panel
  - 7. Aprobaciones: el trabajo principal
  - 8. Consola
  - 9. Contenciones activas y el freno de emergencia
  - 10. Decisiones
  - 11. Incidentes y casos
  - 12. Red
  - 13. Ubicaciones y Watchlist
  - 14. Trazas
  - 15. Informe y PDF
- **Parte III · Configuración (administrador)**
  - 16. Políticas de respuesta
  - 17. Conectividad: cómo entra el MDR en cada equipo
  - 18. Estado de servicios
  - 19. El perfil de la red del cliente
  - 20. Recortes ante fallos de contención
- **Parte IV · Referencia**
  - 21. Las diez familias de ataque
  - 22. Por qué falló una contención (F1 a F10)
  - 23. Variables de entorno
  - 24. Ficheros que escribe el sistema
  - 25. Problemas comunes
  - 26. Lo que el sistema no hace

Qué hace el sistema

El MDR recibe las alertas que ya generó el SIEM del cliente (en el laboratorio, Wazuh) y las **refina**. Decide cuáles son amenazas reales y cuáles ruido, propone una respuesta y, si la política del cliente lo permite, la ejecuta en el equipo afectado.

El camino de cada alerta es siempre el mismo:

1. **Agrupa** las alertas repetidas en un incidente y suprime las que ya se decidieron.
2. **Clasifica** el incidente en una de diez familias de ataque, o lo marca como falso positivo o «no soportada».
3. **Propone una acción** del catálogo cerrado: bloquear una IP, cortar una conexión, aislar un equipo, etc. La propone una política determinista; el modelo de lenguaje solo redacta la explicación.
4. **Filtra la acción con el perfil del cliente.** La permite en automático, la retiene para un analista, la sustituye por una más suave o la veta.
5. **Ejecuta y verifica** por SSH, con un usuario de mínimo privilegio en el equipo.
6. **Escala si no puede contener en el equipo.** Sube por la cadena de cortafuegos hasta el perímetro.
7. **Lo anota todo** en una traza encadenada por hash, que no se puede alterar sin que se note.

Tres ideas que conviene tener presentes:

- **El MDR no detecta: refina.** Lo que el SIEM no ve, el MDR tampoco.
- **Lo que roza un servicio lo decide una persona.** La consola existe para eso.
- **Ante la duda, lo más grave.** Si algo no cuadra, el sistema retiene o avisa; nunca da algo por contenido sin haberlo verificado.

Parte I · Puesta en marcha

1. Requisitos

Qué	Para qué
Python 3 (probado en 3.14) con PyYAML	El MDR. No hace falta entorno virtual.
Docker y Containerlab	El laboratorio del banco.
Node.js y npm	Construir la consola web (`visor/`).
Opcional: llama.cpp y el modelo en `modelos/`	Solo para `--con-llm` (justificación con el modelo de lenguaje).

La consola web hay que construirla una vez, y de nuevo cada vez que cambie su código. El MDR sirve la carpeta `visor/dist`, que no viene en el repositorio:

```
cd visor && npm install && npm run build && cd ..
```

Sin ella la API funciona, pero la página no carga.

2. Arrancar el laboratorio y el MDR

2.1 Levantar la red del banco

```
sh lab/lab.sh up banco
```

Despliega los equipos del banco: servidores, cortafuegos, el SIEM Wazuh y el nodo de gestión del MDR. Tarda unos minutos.

2.2 Dar acceso al MDR a los equipos

Hay dos formas. Hay que elegir una cada vez que se levanta la red.

- **Con el script (rápido):**

  ```
  sh lab/banco/banco.sh aprovisionar
  ```

  Crea en cada equipo el usuario `triaje`, instala la clave del conector y el sudoers de mínimo privilegio.

- **Desde la consola, equipo a equipo (como en un cliente real):** se arranca el MDR sin aprovisionar y cada equipo se da de alta en la vista **Conectividad** (§17). El paso a paso está en `PLAN-PRUEBA-CONECTIVIDAD-SIN-SCRIPT.md`.

Comprobación opcional de que la red responde:

```
sh lab/banco/banco.sh test
```

2.3 Arrancar el MDR con la consola web

```
sh reiniciar.sh
```

Esto hace lo siguiente:

- detiene el MDR anterior, si lo había;
- arranca uno nuevo leyendo las alertas de Wazuh, con el perfil del banco;
- escribe una traza nueva en `run/trazas-AAAA-MM-DD-HHMM.jsonl`.

Opciones habituales:

Comando	Cuándo
`sh reiniciar.sh`	Lo normal.
`TRIAJE_CONECTIVIDAD_ABIERTA=1 sh reiniciar.sh`	Laboratorio sin tokens de operador: deja probar y editar Conectividad.
`TRIAJE_CONSOLA_OPERADORES='{"tok-ana":"ana"}' sh reiniciar.sh`	Con un token por analista (§3).
`sh reiniciar.sh --con-llm`	Experimental: justificación redactada por el modelo de lenguaje.

Las variables se pueden combinar. La lista completa está en el §23.

2.4 Abrir la consola

Abre **http://127.0.0.1:8787** en el navegador del mismo equipo. La consola solo escucha en ese equipo.

2.5 Lanzar ataques de prueba

En otra terminal:

```
sh lab/banco/banco.sh atacar
```

Abre un menú con trece ataques que cubren las diez familias. Variantes:

- `atacar auto`: los lanza todos una vez, sin preguntar.
- `atacar continuo`: ataques sin fin, para pruebas de carga.

`sh lab/banco/banco.sh vigilar` muestra en la terminal la salud de los servicios del banco.

3. Entrar en la consola

La consola tiene tres modos, según cómo se arrancó el MDR:

Modo	Cómo se configura	Qué ve el analista
Abierta	Sin token: lo normal en el laboratorio	Pide «¿Quién está al mando?» y un nombre. Arriba aparece la banda «Consola abierta».
Compartida	`TRIAJE_CONSOLA_TOKEN=<token>`	Pide el token común y después un nombre. El nombre no se verifica.
Identificada	`TRIAJE_CONSOLA_OPERADORES='{"token":"nombre", …}'`	Pide el «Token de operador». El nombre sale del token y firma cada acción.

Detalles de la pantalla de acceso:

- **«Mantener la sesión en esta pestaña»** (marcada por defecto) guarda el token solo en esa pestaña. Nunca se guarda en disco. Sin la casilla, al recargar se vuelve a pedir.
- **Intentos fallidos:** cinco tokens distintos fallidos en un minuto bloquean el acceso 30 segundos («Demasiados intentos», con cuenta atrás).
- **Token que caduca:** si el token deja de valer mientras trabajas, aparece encima de la vista el aviso **«Volver a entrar»**. Al entrar de nuevo sigues donde estabas.

Qué exige un operador identificado. Aprobar, rechazar, pausar y revertir solo exigen haber entrado. En cambio, **editar Políticas y todo lo que modifica Conectividad** exige un operador identificado por su token. En el laboratorio se puede saltar con `TRIAJE_POLITICA_ABIERTA=1` y `TRIAJE_CONECTIVIDAD_ABIERTA=1`.

4. Detener el sistema

Qué	Cómo
El MDR	Ctrl+C en su terminal. Al salir imprime un resumen de la sesión.
Deshacer los bloqueos del laboratorio sin apagarlo	`sh lab/banco/banco.sh restaurar`
Toda la red del laboratorio	`sh lab/lab.sh down banco`

Al reiniciar el MDR **se pierden** la pausa de la automatización, el estado operativo de Conectividad y la memoria de fallos. Todos viven en memoria. La traza, las políticas, el inventario y las contenciones activas sí se conservan.

Parte II · Uso diario (analista)

5. La pantalla

Menú lateral

Grupo	Vistas
—	**Panel**
Operar	**Consola**, **Aprobaciones**, **Contenciones activas**, **Decisiones**
Investigar	**Incidentes**, **Red**, **Ubicaciones**, **Watchlist**, **Trazas**
Informar	**Informe**
Configurar	**Políticas de respuesta**, **Conectividad**, **Estado de servicios**

Señales del menú, de un vistazo:

- **Número ámbar en Aprobaciones:** decisiones que esperan a un analista. Es lo que pide acción.
- **Números en Contenciones activas e Incidentes:** bloqueos vigentes y campañas sin resolver.
- **Punto verde en Consola:** el registro vivo está llegando.
- **Icono rojo en Estado de servicios.** Indica una de estas cosas:
  - un servicio caído;
  - el conector sin configurar;
  - algún equipo con un problema de conexión o configuración (clave del host cambiada, sin aprovisionar, contención fallida o sin acceso).

  Al pasar el ratón por encima se ve el motivo.
- **Plegar el menú:** el botón del pie deja solo los iconos. Se recuerda en el navegador.

Cabecera

- **«datos en vivo»** o **«sin conexión con el daemon»**. Si se pierde la conexión, cada vista sigue mostrando lo último que recibió, con un aviso de la hora.
- **Campana.** Activa los avisos del navegador. Cuando llega una decisión **nueva** que espera aprobación, el navegador lo notifica aunque estés en otra pestaña, con un pitido corto. La pestaña muestra siempre el número de pendientes: «(3) MDR — consola de triaje».
- **Sol o luna:** tema claro u oscuro.
- **Tu nombre.** Su menú muestra cómo firmas, desde cuándo estás dentro, «Cambiar nombre» (si no estás identificado por token) y «Cerrar sesión».

Banda de pausa

Con la automatización en pausa, una banda roja arriba avisa de que «toda contención automática espera aprobación humana». Su botón «Gestionar» lleva a Contenciones activas.

6. Panel

Responde a «¿funciona todo?» y «¿qué me toca?».

La línea de salud. Resume la plataforma en una frase y cuatro indicadores:

- **Servicios:** cuántos están en pie.
- **Ingesta:** cuándo llegó la última alerta del SIEM. Verde si fue hace menos de 2 minutos, rojo pasados 15.
- **Traza:** «íntegra» o «rota».
- **Conector:** cuántos equipos están verificados o con problemas.

Las cifras del día.

- Decisiones de hoy, comparadas con ayer a la misma hora.
- Contenidas en automático.
- Esperan a un humano, con cuántas están fuera del SLA.
- Incidentes abiertos.
- Ruido evitado.

Las dos que piden acción se pueden pulsar.

«Te toca». Lo que necesita a un analista, por orden de urgencia:

- **Las aprobaciones más cercanas a vencer el SLA**, con su barra de tiempo y el botón «Revisar».
- **Equipos sin acceso:** «El MDR no tiene acceso a X desde las HH:MM».
- **Campañas sin responsable**, con «Asignarme».
- **Contenciones fallidas**, con su causa en lenguaje claro. Lo que **puede ser un ataque** aparece primero y en rojo como «Posible ataque en X», aunque la escalada lo haya contenido en otro equipo.

Actividad y rankings. Actividad de las últimas 24 horas por hora, qué se está atacando, los equipos más atacados y las últimas decisiones.

7. Aprobaciones: el trabajo principal

Aquí esperan las decisiones que el perfil del cliente no deja ejecutar solas: tocan un servicio, un activo crítico o son acciones que nunca se automatizan. **El SLA es de 15 minutos.**

7.1 La lista

Cada fila muestra:

- la gravedad (barra de color, de P1 a P4);
- «equipo · familia → ACCIÓN»;
- las marcas «cascada» (la acción tumbaría otros servicios) y «escalada» (es un salto al cortafuegos);
- la IP de origen y su país;
- «sigue atacando +N»: repeticiones llegadas mientras esperaba;
- la edad, con su barra de SLA, que se pone roja al vencer.

Para ordenar y filtrar:

- **Filtros:** «Todas», «Fuera de SLA», «Críticas», «Con cascada», «Sigue atacando».
- **Ordenar:** más recientes, más antiguas, urgencia o gravedad.
- **Agrupar:** por país, por campaña /24, por equipo, por familia o por gravedad.

Ordenar y agrupar se recuerdan en el navegador.

7.2 El inspector

A la derecha está todo lo necesario para decidir:

- **«Si apruebas».** Qué se ejecuta, contra quién y con qué consecuencia. Si hay cascada, la lista de equipos que caerían.
- **«Si rechazas, no se ejecuta nada».**
- **«Por qué lo propone el motor».** Clase, confianza, por qué necesita a un humano y técnica ATT&CK.
- **El origen** y **lo que ya pasó con él**: sus últimas decisiones.

7.3 Decidir

Botón	Tecla	Qué hace
Aprobar	A	Ejecuta la acción. Si hay cascada, pide confirmar «Aprobar igualmente».
Rechazar	R	No ejecuta nada. La amenaza queda registrada.
Reclasificar	C	La clase estaba mal: eliges la correcta. No ejecuta nada y queda como corrección del motor.

- **Nota opcional.** El campo «Nota para la traza…» guarda tu comentario en el caso.
- **Atajos de teclado:** J y K (o las flechas) para moverse, X para marcar. No actúan mientras escribes ni con un diálogo abierto.
- **Decidir en bloque:** marca varias y usa «Aprobar las N» o «Rechazar las N». **Aprobar** en bloque pide confirmación; **rechazar** en bloque, no.
- **«No se aplicó el veredicto»:** otro analista la resolvió antes, o la decisión cambió. Mira la cola de nuevo.

Escaladas. Si apruebas y el equipo atacado no responde, el MDR intenta contener en su cortafuegos. Si ese salto también necesita a un humano, aparece como una aprobación nueva con la marca «escalada». Las escaladas solo tienen Aprobar y Rechazar.

8. Consola

Es el registro vivo del MDR, lo mismo que imprime su terminal: incidentes, decisiones, cada comando que se ejecuta por SSH, verificaciones, escaladas, reversiones y avisos. Guarda las últimas 1000 líneas.

- **Filtros:** «Todo», «Decisiones», «Incidentes», «Ejecución», «Avisos», y un campo para filtrar por texto.
- **Desplazamiento automático:** se pausa si subes a leer y se reanuda al bajar al final.

Qué significa el símbolo del principio de cada línea:

Símbolo	Significado
⚠	Incidente nuevo

Símbolo	Significado
▶	Orden ejecutada en un equipo, con su comando exacto
✔	Verificada: la contención está puesta
✗ … NO verificada / ✗ … no se ejecutó	La contención no quedó: dice dónde, por qué y qué hacer
· … evidencia:	La salida real de SSH o sudo que lo prueba
⇪	Escalada: dónde contuvo o en qué equipos falló. «POSIBLE ATAQUE» si lo es.
↶	Reversión
✓ ↻	Veredicto de un analista
☰	Cambio en un caso
↩	Repetición suprimida (ruido)
↺	Actividad propia del MDR (su propio SSH visto por el SIEM)
	Pausa de la automatización
[aviso]	Aviso del sistema, por ejemplo «el MDR no tiene acceso a X»

9. Contenciones activas y el freno de emergencia

Lista lo que está bloqueado **ahora**. En cada fila:

- qué se bloqueó y a quién protege;
- quién lo decidió: «automática», «vía escalada» o «aprobó Fulano»;
- su antigüedad;
- **cuántos intentos paró**. Una contención con intentos parados está sirviendo.

El inspector muestra la gráfica de intentos antes y después del bloqueo, la regla exacta que se aplicó y el comando que la quita.

Pausar la automatización (el «kill switch»)

El interruptor **«Automatización»** pone el MDR en pausa con un clic, **sin confirmación**:

- desde ese momento, **toda** contención nueva espera a un analista;
- pausar **no** retira las contenciones que ya están puestas;
- queda anotado en la Consola con tu nombre;
- se pierde si se reinicia el MDR.

Revertir

Botón	Qué hace
«Revertir…»	Quita una contención. Pide confirmación.
«Revertir y vigilar…»	La quita y añade la IP a la Watchlist.
«Revertir las N…»	Las seleccionadas.
«Revertir todas (N)…» / «Revertir las de más de 7 días (N)…»	En masa. **Hay que escribir el número de contenciones** para habilitar el botón.

Revertir es real: el MDR quita la regla en el equipo y lo anota en la traza con tu nombre. Si el origen sigue intentándolo, volverá a llegar.

10. Decisiones

El historial de lo que decidió el motor y en qué acabó.

La franja de arriba filtra al pulsarla:

- Decisiones;
- Contenidas en automático;
- Pasaron por un analista;
- Corregidas por el analista;
- Frenadas por la política;
- Contención fallida.

Búsqueda y filtros:

- un buscador por equipo, IP, identificador o país;
- un selector de clase;
- filtros como «Pendientes», «Falsos positivos» o «Decididas por mí»;
- la casilla **«Incluir registros del sistema»**, para ver reversiones y supresiones.

El desenlace de cada decisión va en una píldora de color:

Color	Desenlaces
Verde	contenida
Rojo	fallida, vetada
Ámbar	rechazada, pendiente, degradada
Violeta	reclasificada
Gris	enrutada, falso positivo, no soportada, sin acción

El detalle de una decisión

El detalle se lee como una historia de seis pasos:

1. la alerta del SIEM;
2. la clasificación;
3. la propuesta del motor;
4. la política del cliente («automática», «retenida — espera tu aprobación», «degradada», «vetada»);
5. el analista;
6. la ejecución.

La ejecución dice dónde quedó contenida, si escaló desde otro equipo, si se ejecutó, si se verificó y el comando exacto.

Si la contención falló, cada intento lleva su **causa en lenguaje claro**, con la evidencia debajo. Por ejemplo: «intento en atm: equipo sin aprovisionar — dalo de alta o fija su clave del host en Conectividad».

- Las causas que **pueden ser un ataque** van en rojo con la marca **POSIBLE ATAQUE**. Son tres: la clave del equipo cambió, la contención se aplicó y alguien la deshizo, o un equipo que funcionaba dejó de hacerlo. **No las trates como un problema de configuración**: compruébalo por otro canal antes de tocar nada.
- **«Salto de respaldo»** significa que el perfil tenía la cadena de cortafuegos rota y la escalada siguió hasta el perímetro. Hay que corregir el perfil (§19).

El detalle también incluye la justificación (por plantilla o redactada por el modelo, con el conocimiento que consultó), el origen y **«Qué hacer después»**: la recomendación y los pasos del runbook.

Desde aquí se abre:

- **el grafo del incidente**: el ataque dibujado sobre el mapa de la red;
- **el perfil del atacante**;
- **la contención**;
- **la prueba de integridad en Trazas**.

11. Incidentes y casos

Un incidente agrupa los ataques de un mismo bloque de IPs (/24): es la **campaña**. Cada uno muestra:

- su estado: «Nuevo», «En revisión» o «Resuelto»;
- si está activo ahora: punto rojo, ha atacado en la última hora;
- su responsable.

El panel del caso cuenta la historia del ataque: contra qué equipos, cuántas decisiones y bloqueos, y la cronología.

Gestionar el caso:

- **Estado:** Nuevo → En revisión → Resuelto.
- **Responsable**, con el botón «asignarme».
- **Nota**: «Guardar en el caso».
- **«Resolver con esta nota».** Para cerrar hay que escribir por qué.

Cada cambio queda en la traza con tu nombre y la hora. El historial de un caso no se puede borrar.

12. Red

El mapa de la red del cliente, con la actividad de cada equipo. Se lee de arriba abajo:

- **El carril de arriba:** internet y los orígenes que más atacan.
- **El tronco:** los cortafuegos.
- **Las ramas:** las zonas, cada una colgada del cortafuegos que la protege. Si hay una red detrás de su propio cortafuegos, sale en su propia rama.

Estado de cada equipo:

Símbolo	Estado
⚠	atacado
▯	espera tu decisión
✓	contenido
⚠	caería en cascada
↗	origen de ataques
×	caído
○	sin actividad

Capas que se activan y desactivan:

- **«ataques»:** flechas rojas desde el origen. El grosor indica el volumen.
- **«cascada»:** en ámbar, de un equipo caído a los que dependen de él.
- **«dependencias»:** en violeta, quién depende de quién. Dentro de una misma zona se dibuja como un arco por la derecha de la columna.

Otras acciones:

- **«solo con actividad»** pliega las zonas tranquilas. Una zona también se pliega pulsando su píldora.
- **El buscador** encuentra un equipo por nombre o IP.
- **Al seleccionar un equipo** se atenúa lo que no tiene relación con él y se abre su ficha: riesgo, ataques recibidos y contenidos, atacantes (por IP o por subred), eventos recientes y enlaces a sus decisiones.

Avisos del perfil. Si el perfil de la red tiene algo roto, una franja ámbar encima del mapa lo lista. Por ejemplo: «su gateway fw-core no está en la topología». Los equipos y las dependencias del mapa salen del perfil del cliente, no de Conectividad; cómo cambiarlos está en el §19.

Perfil del atacante. Se abre pulsando una IP. Muestra:

- su riesgo;
- los equipos que atacó;
- su actividad por día y su línea de tiempo;

- **«DNS inverso: Resolver»**, que solo consulta si lo pides y solo para IPs públicas.

13. Ubicaciones y Watchlist

Ubicaciones muestra en un mapamundi de dónde vienen los ataques. La geolocalización es aproximada y no consulta servicios externos. Hay tres métricas:

- **«En curso»:** ataques aún no contenidos.
- **«Total».**
- **«Mitigados».**

Al pulsar un país, «En curso» lleva a Aprobaciones de ese país; las otras dos, a Decisiones. Las IPs internas, de laboratorio o sin geolocalizar solo aparecen en la tabla.

Watchlist es tu lista de indicadores sospechosos: una IP o un bloque /24, con una nota. **Es solo una anotación**: no cambia ninguna decisión del motor. Las IPs vigiladas aparecen marcadas con ⚑ en la Red y en el perfil del atacante. «Quitar» no pide confirmación.

14. Trazas

El registro auditable: cada decisión, veredicto, reversión y cambio de caso, encadenado por hash.

- **La franja de arriba** dice «Cadena íntegra» o «Cadena rota en el registro #N». Se comprueba cada 30 segundos, y con «Verificar ahora» en el momento.
- **Cada fila** lleva su marca:
  - ✓ verificado;
  - ✗ alterado;
  - ⚠ posterior a una rotura.
- **El inspector** muestra el registro, su «Causa del fallo» si la tiene, y la prueba de la cadena (el hash anterior y el suyo).
- **«Copiar el registro (JSON)»** lo copia para auditarlo fuera.

Si la cadena se rompe, el inspector abre directamente el registro alterado.

15. Informe y PDF

Elige el periodo: «En vivo», «Este mes», «Este año» o «Rango…».

Qué muestra:

- **Indicadores:** tasa de falsos positivos, resuelto sin humano, escalado a humano, tiempo medio de respuesta (MTTR), dentro del SLA y alertas de ruido evitadas.
- **Gráficas y rankings:** activos más atacados, familias, orígenes y decisiones por analista.
- **La cobertura MITRE ATT&CK.**
- **Un resumen redactado.**

Exportar a PDF:

1. **Elige un periodo cerrado.** El modo en vivo no se exporta.
2. **En «Qué incluir», marca las secciones.** Por defecto van todas salvo el anexo con el detalle de cada decisión.
3. **Rellena «Para»**, el cliente y el área destinataria. Debajo verás el nombre del archivo, por ejemplo `Informe-MDR-2026-11`.
4. **Pulsa «Vista previa del PDF».** Se abre el documento en hojas A4, con:
   - portada;
   - comparación con el periodo anterior;
   - recomendaciones;
   - integridad de la traza;
   - el pie «Confidencial · uso interno del cliente».
5. **Pulsa «Guardar PDF»** y, en el diálogo de impresión del navegador, elige guardar como PDF.

Parte III · Configuración (administrador)

16. Políticas de respuesta

Decide qué respuestas se ejecutan solas y cuáles esperan a un analista. **Cada clic se guarda al momento, sin confirmación**, y queda en la auditoría con tu nombre. Hace falta un operador identificado por su token.

«Por tipo de ataque». Cada familia muestra su acción y un selector **AUTO / HUMANO**.

- Las que llevan **candado** («freno duro / nunca automática») no se pueden poner en automático.
- Las que «se trían y enrutan» no tienen acción que ejecutar.
- «detalle» muestra el impacto, los vetos y el runbook.

«Por zona y dispositivo».

- **Postura por zona:** AUTO o HUMANO. Las zonas protegidas (el plano de gestión) no se editan.
- **Por equipo:** HEREDA, AUTO o HUMANO, con su criticidad y cuántos equipos caerían en cascada si se le aísla.

Cuál manda. Si la familia **o** la zona está en HUMANO, prevalece HUMANO. La capa de la consola solo puede **quitar** automatización respecto al perfil; nunca añadirla.

17. Conectividad: cómo entra el MDR en cada equipo

El MDR contiene entrando por SSH en cada equipo con un usuario propio (`triaje`). Ese usuario solo puede ejecutar, por sudo, los comandos del catálogo que permite el **papel** del equipo. Esta vista lo gestiona todo sin tocar scripts.

Es una vista delicada, por tres motivos:

- La **clave privada del conector nunca llega al navegador**; solo se ven la pública y las huellas.
- **Ninguna clave del host se acepta sola.** Siempre hay que confirmar que la huella coincide con la que imprimió el equipo.
- **Para probar o cambiar algo hace falta un operador identificado.**

17.1 Arriba de la vista

- **La franja de permisos** dice qué puede hacer tu sesión.
- **La clave del conector**, con su huella y «Copiar clave pública». Si no existe, «Generar la clave del conector», recomendada en ed25519.
- **El usuario por defecto en los equipos.**
- **Las cifras:**
  - equipos contenibles;
  - conexión verificada;
  - clave del host cambiada;
  - sin aprovisionar.

- **Los botones:** «+ Añadir equipo», «Rotar la clave del conector…» y «Probar todos».

17.2 La tabla de equipos

Para cada equipo: papel, estado de la conexión, si las reglas de su sudoers coinciden con su papel y su clave del host.

Estado	Significado
verificada	La última prueba pasó. Con más de 24 h, «conviene volver a probar».
bloqueada	**La clave del host cambió.** Puede ser una suplantación.
privilegio de más	sudo permite más de lo que su papel necesita.
sin aprovisionar	No acepta la clave del conector o falta su clave del host.
sin acceso / fallo	No se pudo conectar, o el comando falló.
sin probar / alta pendiente	Aún no se ha probado / se está dando de alta.

Aviso rojo encima del estado. Aparece cuando una **contención real** falló en ese equipo: «la última contención falló», «posible ataque» o «sin acceso». Ese aviso **solo resta confianza**: una prueba verde anterior no lo tapa. Se quita con una contención correcta o con una prueba nueva que pase.

17.3 Dar de alta un equipo

Pulsa **«+ Añadir equipo»** y sigue los cuatro pasos:

1. **Inventario:** nombre, IP, zona (una de las que ya existen), función, criticidad, interfaz y de qué equipos depende.
2. **Papel y reglas:** servidor, cortafuegos o puesto. El papel marca las acciones que se pueden ejecutar en ese equipo. Puedes añadir los servicios que se pueden parar y las cuentas que se pueden bloquear; las cuentas del sistema nunca se bloquean.
3. **Paquete de alta.** Un script, un playbook de Ansible o solo el sudoers, que **el administrador del equipo ejecuta en él**:
   - lleva solo la clave pública;
   - no pide contraseñas de administrador;
   - crea el usuario `triaje` y su sudoers;
   - aparta los sudoers antiguos del conector.
4. **Verificar y dar de alta:** «Leer la clave del equipo», marcar **«Coincide con la que imprimió el equipo»** y «Dar de alta». Hace la prueba completa y, si pasa, el equipo entra en el motor y en el mapa.

Hasta que el alta se completa, el equipo está «pendiente» y el MDR no actúa en él.

17.4 Un equipo ya existente

Su inspector tiene:

- **«Fijar la clave del host»** para un equipo que nunca se conectó: «Leer la clave del equipo», comparar, «Fijar esta clave».

- **«Clave del host cambiada».** Muestra la fijada frente a la que presenta ahora, con el aviso de posible suplantación. **Compruébalo por otro canal** antes de pulsar «Aceptar la nueva clave…».
- **«Papel y reglas»:** cambiar el papel o quitarlo. Si alguien tocó el sudoers del equipo, verás lo que **sobra** (rojo) y lo que **falta** (ámbar), y podrás «Generar paquete de corrección».
- **«Cómo entra el conector»:** puerto y usuario. «Probar y guardar» solo guarda si la prueba pasa.

Quitar equipos. Solo se pueden quitar las altas pendientes y los papeles. Un equipo ya dado de alta se quita de `run/inventario-operativo.yml`, y luego hay que reiniciar el MDR.

17.5 Rotar la clave del conector

Se hace en tres fases. Ningún equipo se queda sin acceso por el camino:

1. **«Iniciar: generar el par nuevo».**
2. **«Añadir y probar en todos»:** la clave nueva entra en cada equipo junto a la vieja y se prueba.
3. **«Retirar la clave vieja…»** (pide confirmación; desde ahí ya no se puede cancelar) y **«Finalizar»**.

17.6 Lo que Conectividad no hace

- **No crea los equipos de la red.** El mapa y el motor los toman del perfil (§19). Conectividad solo gestiona cómo se entra en ellos, más las altas nuevas.
- **No arregla equipos sola.** Reaprovisionar o aceptar una clave siempre lo decide una persona.

18. Estado de servicios

Solo es de consulta.

- **«MDR propio».** Si el lazo de decisión está vivo, cuándo llegó la última alerta del SIEM y cuántas alertas se procesaron.
- **«Conector».** Cuántos equipos están verificados o con problemas, con el enlace a Conectividad.
- **Los servicios del cliente**, con los caídos primero:
  - si un servicio está caído, dice «afecta a …» los que dependen de él;
  - si depende de uno caído, dice «responde, pero X está caído».
- **Muestra vieja.** Si la muestra del monitor tiene más de un minuto, la vista avisa de que lo que enseña es lo último que se supo.

El icono de esta vista en el menú se pone **rojo** con cualquiera de los problemas que lista el §5.

19. El perfil de la red del cliente

Todo lo que el MDR sabe del cliente vive en su **perfil**, por ejemplo `prototipo/perfiles/bancario.yml`. **Los cambios en el perfil exigen reiniciar el MDR.**

Sección	Qué define
`activos`	Los equipos: IP, función, criticidad, servicios y **de quién dependen** (`depende_de`)

Sección	Qué define
`topologia`	La cadena de contención: qué equipos se contienen y cuál es su cortafuegos (`gateway`)
`red`	Para el mapa: nodos extra (internet, switches), enlaces y zonas
`ip_gestion` , `redes_internas`	El plano de gestión, que nunca se corta, y las redes propias
`origenes_legitimos` , `terceros_confiables`	Quién no es atacante, y a quién no se bloquea sin humano
`continuidad` , `excepciones`	Qué se automatiza según el impacto, y los servicios que nunca se tocan solos
`rutas`	Adónde se enruta lo que no se contiene (por ejemplo, appsec)

Las dependencias (`depende_de`) deciden la **cascada**. Por ejemplo, si `middleware` depende de `core-db` y cae `core-db` , middleware cae con él. El motor usa este dato para no aislar algo que tumbe servicios sin que un humano lo apruebe. El mapa lo dibuja en la capa «dependencias».

Añadir una red nueva. Hay que completar cuatro sitios:

1. sus equipos en `activos` ;
2. su cortafuegos y sus equipos en `topologia` , con su `gateway` ;
3. sus enlaces en `red.enlaces` ;
4. la zona en `red.zonas` .

Si solo se añaden los `activos` , los equipos salen en «Sin ubicar» y la escalada usa los cortafuegos perimetrales en vez del suyo. Una vez creada la zona, Conectividad ya puede dar de alta equipos en ella, y heredan el cortafuegos de sus vecinos.

Borrar un equipo. Hay que quitarlo de **todas** las secciones. Si se borra a medias, el MDR lo avisa al arrancar (en la Consola) y en la franja ámbar del mapa de Red:

Si queda…	Qué pasa
en `topologia` , pero no en `activos`	Se sigue pintando y **se sigue conteniendo** en él
otros equipos que dependían de él	Su cascada desaparece
un `gateway` apuntando a un cortafuegos borrado	La escalada salta a los cortafuegos perimetrales («salto de respaldo»). **La cuarentena (AISLAR_NODO) de esos equipos deja de poder ejecutarse** hasta que se corrija.

El historial del equipo borrado se conserva en Decisiones y en Trazas.

20. Recortes ante fallos de contención

Están **apagados por defecto**. Se encienden con `=1` al arrancar el MDR. No cambian qué se contiene: solo ahorran conexiones que no podían servir.

Variable	Efecto
`TRIAJE_FALLO_RAPIDO`	Si la primera conexión ni siquiera entra en el equipo, no se repite contra él. La escalada sigue igual.
`TRIAJE_PRECHECK_APROVISIONADO`	No intenta en un equipo que la consola sabe sin clave del host. Escala, o queda fallida con su motivo.
`TRIAJE_ESCALADA_SOLO_APROVISIONADOS`	Salta los cortafuegos de escalada sin aprovisionar y lo anota («salto omitido»).
`TRIAJE_MEMORIA_FALLOS`	Tras 3 fallos de acceso seguidos a un equipo en 5 minutos, deja de intentar en él y escala directo. Avisa **una vez** («el MDR no tiene acceso a X») y lo reprueba cada 60 s sin sudo. Se cierra al primer acceso.
`TRIAJE_ACCION_NO_EJECUTABLE`	Si la prueba de Conectividad de las últimas 24 h dice que falta la regla de esa acción en el sudoers, no la intenta.

Ninguno se activa ante una clave del host cambiada ni ante una contención deshecha. Esas dos pueden ser un ataque y se quieren ver en cada intento. El diseño completo está en `PLAN-MANEJO-FALLOS-CONTENCION.md`.

Parte IV · Referencia

21. Las diez familias de ataque

Familia	Respuesta	¿Puede ser automática?
acceso_credenciales (fuerza bruta)	BLOQUEAR_IP en el equipo; si falla, en el cortafuegos	Sí, si el perfil lo permite y la confianza llega al umbral
reconocimiento (escaneos)	BLOQUEAR_IP	Igual que la anterior
servicio_expuesto	BLOQUEAR_IP si el servicio está expuesto; si no, falso positivo	Igual que la anterior
explotacion_conocida	Se tría y se **enruta** al equipo de appsec; no se contiene	—
abuso_de_cuenta	FORZAR_CAMBIO_PASS (bloquea la cuenta)	**Nunca**
integridad_fichero	AISLAR_NODO (cuarentena en el cortafuegos de borde)	**Nunca**
denegacion_servicio	LIMITAR_BANDA en la víctima	**Nunca**
acceso_consumado	MATAR_CONEXION (corta la sesión viva)	Según el perfil
exfiltracion	BLOQUEAR_DESTINO en el borde	**Nunca**
malware	AISLAR_NODO	**Nunca**

Lo que no encaja en ninguna familia se marca **«no soportada»** y no se actúa. Si es grave, pasa a un analista.

22. Por qué falló una contención (F1 a F10)

Cuando una contención no queda, el MDR dice por qué. Lo ves en la Consola, en Decisiones, en Trazas y en «Te toca».

Clase	Qué pasó	Qué hacer
F1	Orden rechazada antes de salir	Revisa la alerta: un parámetro no era válido
F2	Equipo sin aprovisionar	Dalo de alta o fija su clave del host en Conectividad
F3	**La clave del host cambió**	**Posible suplantación.** Compruébalo por otro canal antes de aceptar la clave
F4	El equipo no acepta la clave del conector	Ejecuta su paquete de alta
F5	Equipo inalcanzable	Comprueba que el equipo y sshd están en marcha y que la red llega

Clase	Qué pasó	Qué hacer
F6	sudo deniega la acción	Revisa el papel y el sudoers. Si falta la regla, es una «acción no ejecutable en este equipo».
F7	La acción falló dentro del equipo	Revisa la salida del comando
F8	**Se aplicó, pero ya no está**	**Posible contramedida:** alguien pudo deshacerla
F9	El conector no tiene clave	Genera la clave del conector en Conectividad
F10	Causa no identificada	Revisa la salida en bruto

Regresión. Si el equipo **estaba verificado** y ahora da F4, F5 o F6, el MDR lo marca como **posible ataque**: alguien pudo cortar el acceso del SOC. Compruébalo antes de reaprovisionar.

23. Variables de entorno

Consola y acceso

Variable	Efecto
`TRIAJE_CONSOLA_TOKEN`	Token compartido. Con él, la consola pide token.
`TRIAJE_CONSOLA_OPERADORES`	`{"token":"nombre", …}` : un token por persona, que firma sus acciones.
`TRIAJE_CONECTIVIDAD_ABIERTA=1`	Laboratorio: deja probar y editar Conectividad sin operador identificado.
`TRIAJE_POLITICA_ABIERTA=1`	Laboratorio: deja editar Políticas sin operador identificado.
`TRIAJE_SLA_SEG`	SLA de la respuesta humana en segundos (900 por defecto).
`TRIAJE_RDNS=1`	Permite el DNS inverso de IPs públicas.

Conector

Variable	Efecto
`TRIAJE_NODO_GESTION`	Contenedor desde el que sale el SSH del conector. `reiniciar.sh` la fija en el banco.
`TRIAJE_SSH_MODO`	`clave` (vía el nodo de gestión), `directo` (desde este equipo) o `password` (laboratorio). Sin clave ni modo, no ejecuta nada.
`TRIAJE_SSH_USUARIO` , `TRIAJE_SSH_CLAVE` , `TRIAJE_SSH_KNOWN_HOSTS`	Usuario, clave privada y huellas del conector.

Traza

Variable	Efecto
`TRIAJE_TRAZA_CLAVE`	Firma la cadena de la traza con HMAC. Sin ella, el arranque avisa «SIN firma HMAC».
`TRIAJE_ANCLA`	Ancla la traza en el syslog del SIEM.

Recortes ante fallos: los cinco del §20.

24. Ficheros que escribe el sistema

Todos viven en `run/`, junto a la traza.

Fichero	Contenido
`trazas-*.jsonl`	La traza encadenada. Al reiniciar, el MDR recupera de aquí las contenciones activas.
`politica-operativa.yml`	Lo editado en Políticas.
`politica-auditoria.jsonl`	Quién cambió qué en Políticas.
`conectividad-operativa.yml`	Usuario y puerto por equipo.
`conectividad-auditoria.jsonl`	Cada prueba y cambio en Conectividad.
`conectividad-pruebas.json`	La última prueba de cada equipo.
`conectividad-rotacion.json`	La rotación de clave en curso.
`inventario-operativo.yml`	Los equipos dados de alta desde la consola y sus papeles.
`watchlist.json`	La Watchlist.

Comprobar la traza fuera de la consola:

```
python3 -m prototipo.servicio.traza --verificar run/trazas-….jsonl
```

25. Problemas comunes

Síntoma	Qué pasa y qué hacer
«sin conexión con el daemon»	El MDR no está en marcha. Arráncalo con `sh reiniciar.sh`.
La página no carga, pero la API responde	Falta construir la consola: `cd visor && npm run build`.
«El daemon no reconoce ese token»	Token mal copiado, o el MDR arrancó con otros tokens.
«Demasiados intentos»	Espera los segundos que indica.

Síntoma	Qué pasa y qué hacer
No puedo probar ni editar en Conectividad o Políticas	Hace falta un operador identificado por token, o la opción de laboratorio correspondiente.
«No se aplicó el veredicto»	Otro analista la resolvió antes. Mira la cola de nuevo.
No llegan avisos	Activa la campana y acepta el permiso del navegador. Solo avisa de decisiones **nuevas**.
Todas las contenciones fallan con «equipo sin aprovisionar»	La red se levantó sin aprovisionar. Usa `banco.sh aprovisionar` o da de alta los equipos en Conectividad.
Un equipo da siempre «inalcanzable»	Comprueba que está en marcha. En el laboratorio, `banco.sh restaurar` quita el bloqueo del caso E1.
Icono rojo en «Estado de servicios»	Pasa el ratón para ver el motivo. Abre Conectividad o Estado de servicios.
La Red muestra una franja ámbar de avisos	El perfil tiene algo roto (un equipo borrado a medias, un enlace a un nodo que no existe). Corrígelo y reinicia el MDR.
«Cadena rota» en Trazas	Alguien editó la traza, o se mezclaron dos. Para una sesión limpia, usa una traza nueva (`reiniciar.sh` ya lo hace).
Un ataque no aparece	Wazuh calla 60 s algunas reglas repetidas, y los repetidos ya decididos se suprimen (↩ en la Consola).
`Address already in use`	Quedó otro MDR en marcha. `reiniciar.sh` lo detiene.

26. Lo que el sistema no hace

- **No es un antivirus ni un SIEM.** No ve procesos ni genera la alerta original. Si el SIEM no la ve, el MDR tampoco.
- **No improvisa respuestas.** Solo usa las acciones del catálogo, y lo que no encaja lo marca «no soportada».
- **No arregla equipos solo.** Reaprovisionar, aceptar claves o cambiar el perfil lo decide una persona.
- **El modelo de lenguaje no decide.** Solo explica, y su explicación se descarta si no se apoya en los datos.